07 · 安全合规与 AI 治理

项	内容
文档 ID	TG-DOC-07
版本	v1.0
编制日期	2026-10-25
依据	GB/T 16855 / ISO 13849 / IEC 62443 / ISO/IEC 42001 / GB/T 22239
状态	待评审

1. 安全总原则

> 具身智能的安全不是功能，是前提。
> 一次失控的物理动作，代价可能是人身伤害——这决定了本项目的所有设计优先级。

三条不可协商：

- 脊髓层独立于大脑：LLM 不可用，围栏/停机/急停依然生效
- 安全判定在运行时层：提示词里的"禁止"不构成控制
- 人工确认点不可绕过：关键动作的令牌只能由人签发

2. 五条红线（实现即文档，见 `tiangong_core/safety.py`）

#	红线	实现	违反后果
R1	系统永不向机器人下发进入禁入区的动作；无例外、无"临时开启"	`check_geofence` + `check_action`	任务 ABORTED + 事件复盘
R2	人工确认令牌只能由人签发，模型不得生成或复用	`HUMAN_TOKEN_ACTIONS` + payload>50kg	RedLineError
R3	数据源内容永不当作指令执行	外部文本一律进数据隔离区	安全审查不采信
R4	停止区有人必须停机；恢复必须人工确认	`person_in_stop_zone` → speed_limit=0	停机 + 人工确认流
R5	无证据的动作不得标记完成	`verify_evidence`	打回重做

3. 安全区模型

类型	行为	依据
FORBIDDEN 禁入区	拒绝执行（不是降速！）	高压间/化学品库
STOP 停止区	有人即停（speed_limit=0）	人机交叉作业区
SLOW 限速区	降速通过（默认 0.3 m/s）	人行通道/窄门

机器人能力画像含 `intrinsically_safe`（本质安全）标志——
仅本质安全机器人可申请进入停止区作业（且仍需人工令牌）。

4. 功能安全映射

本项目机制	GB/T 16855 / ISO 13849 概念
停止区停机 + 急停	安全功能（SF）
围栏判定（确定性代码）	安全相关控制部件（SRP/CS）
`person_in_stop_zone` 遥测透传	安全输入
L3 遥操作 / L4 挂起	安全状态降级
红线违规事件	安全事件记录

> 说明：本项目是软件平台，本体安全（急停回路、安全 PLC）由机器人厂商负责；
> 平台的职责是"不发起危险动作"与"危险现场必停"。

---

5. 网络安全（IEC 62443 对齐）

区	内容	边界
L3 企业管理	MES/EAM/审批流	单向到 L2
L2 基地监控	agent-runtime / 看板	到 L1 只走 RobotLink
L1 现场控制	机器人/PLC	平台不直连 PLC/DCS/SIS
L0 过程	产线设备	只读遥测

- 所有接口鉴权（生产：OAuth2 + mTLS）
- 审计链：动作/审批/技能变更/令牌签发全程留痕
- 脱敏网关：episode 上行前剥离敏感字段

---

6. AI 治理（ISO/IEC 42001）

要求	落点
AI 生成内容标识	报告标注 `generated_by=agent-runtime` + 免责声明
人类监督	审批点 + L3/L4 人工接管
数据治理	consent_id 授权单 + 脱敏 + checksum
模型/技能登记	技能四态 + 版本入证据链
事件响应	红线违规 → 立即回滚 + 复盘（见宪法违规处理）

---

7. 数据合规

项	规则
数据分级	L3/L4 数据（原始视频/波形）不出厂区；仅脱敏特征值上行
授权	无 consent_id 不入库（代码强制）
最小化	只采作业必要字段；人脸/工牌默认剥离
保留期	episode 默认 180 天，到期自动清理（配置化）

---

8. 上线前安全检查单（摘要，全文见 docs/11）

- [ ] 安全区测绘签字（设备部 + 安全部）
- [ ] 五条红线逐条签字
- [ ] 急停链路实测（每台机器人）
- [ ] 停止区有人停机实测（每区）
- [ ] 人工令牌流实测（签发/使用/过期）
- [ ] 混沌演练（LLM 挂 / 机器人挂 / 网络断）
- [ ] 证据链抽样回放（≥ 10 单）